

Portfolio Project: Cyber Pharmacy

NIST CSF 2.0 Cybersecurity Maturity Assessment

NIST SP 800-30 Cybersecurity Risk Assessment

Prepared by: Haley Thava

Date: 2026

Disclaimer:

This report is a fictional cybersecurity assessment produced as an academic portfolio project. Cyber Pharmacy is a fictional organisation. The software products mentioned are either fictional or to provide operational realism. Services referenced are to provide operational realism. No actual assessments of any software products or services were made. All findings, maturity scores, identified gaps are related solely to the fictional pharmacy. This entire assessment is fictional, and all the findings in this report are fictional.

Executive Summary

Cyber Pharmacy is a privately owned community pharmacy in Perth, Western Australia, providing dispensing, non-sterile compounding, dose administration aid, vaccination, over-the-counter, and retail services. The pharmacy processes sensitive health, identity, financial, and employee information, all of which are personally identifiable information (PII). The pharmacy relies heavily on cloud-hosted dispensing software, national digital health integrations, and a managed service provider (MSP) for IT support and their dispensing software (A-Dispense).

This assessment reviewed Cyber Pharmacy's cybersecurity posture using a selected set of 20 NIST Cybersecurity Framework 2.0 subcategories across the Govern, Identify, Protect, Detect, Respond and Recover functions. A qualitative risk assessment approach adapted from NIST SP 800-30 was then used to identify and prioritise key cyber risks from observed maturity gaps.

The assessment found that Cyber Pharmacy has a low level of cybersecurity maturity across most assessed areas. Key weaknesses include the absence of a documented cybersecurity strategy, no formal risk register, no defined cybersecurity roles and responsibilities, limited asset and supplier visibility, shared email credentials without multi-factor authentication (MFA), weak user access governance/cybersecurity governance, limited monitoring, no documented incident response plan, and unverified backup and recovery arrangements.

Eight priority risks were identified, including patient data breach through shared email compromise, ransomware disruption, regulatory non-compliance with Privacy Act and My Health Record obligations, managed service provider compromise, embedded device compromise, unauthorised My Health Record access or upload, insider access to patient records, and operational disruption from dispensing system outage.

The highest-priority recommendations are to eliminate shared credentials, enforce multi-factor authentication where supported, define MSP cybersecurity responsibilities, implement a basic incident response plan, verify backup and recovery arrangements, introduce cybersecurity awareness training, establish asset and supplier inventories, and create practical privacy and security policies. These actions should be implemented through a staged 12-month roadmap focused on governance, access control, monitoring, incident response, supplier assurance, and operational resilience.

Overall, Cyber Pharmacy should treat cybersecurity as a patient safety, privacy, regulatory, and business continuity risk, not merely an IT issue. A practical uplift program is required to reduce exposure to ransomware, data breach, system outage, and digital health integrity risks.

Business context

Organisational overview

Cyber Pharmacy is a privately owned community pharmacy located in Perth, Western Australia. The pharmacy has served its community for 15 years under one owner. There are 16 employees in total (6 pharmacists, 1 intern, 5 pharmacy assistants and 4 pharmacy students).

The pharmacy's primary service is to provide dispensed (PBS and Private) medications to its patients. In addition to this the pharmacy does non-sterile compounding, dose administration aids (DAA), vaccinations, over the counter (OTC) sales and regular store sales.

The pharmacy does not have a dedicated IT team or staff member trained in IT or cybersecurity. All of the pharmacy's IT related support is conducted by their local Managed Service Provider (MSP).

Data holdings

Cyber Pharmacy holds and processes several categories of sensitive personal identifiable information (PII) making it a meaningful target for cyber criminals. The PII is regulated under the Australian Privacy Law, mainly The Privacy Act 1988 and Medicines and Poisons Act 2014.

Categories of data include:

- Patient health records
 - Patient names, DOB, address, Medicare numbers, allergies, dispensing history.
 - This dataset is highly confidential and could result in major consequences if compromised.
- Employee records
 - Employee TFN, bank details, address, phone number.

System environment

The pharmacy operates on A-Dispense which is a cloud hosted and point of sale platform provided by A-Software. A-software also acts as Managed Service Provider for IT support. All dispensing work stations are connected to the vendor's cloud service over HTTPS. The pharmacy is integrated with national health infrastructures including eRx, Active Script List (ASL), My Health Record (MHR), PBS Online and Australian Immunisation Register (AIR). Business operations are further supported by additional software including Online Cloud S8 registry and a shared Email account for all external emails.

The network consists of a single consumer grade modem, which provides a flat (un-segmented) internet service for the pharmacy. The modem doesn't have a firewall configured and no out-bound filtering for connected devices on the network.

Importance of cybersecurity

Cybersecurity is directly relevant to the pharmacy's core obligations across 3 dimensions:

- **Patient safety**
The confidentiality, integrity and availability of the patient's medical records and PII underpins safe medication supply. If this data's confidentiality, integrity or availability is compromised in any way, it could result in dispensing errors with clinical consequences. This will directly violate legislations (e.g Privacy Act 1988 and Medicines and Poisons Act 2014), regulatory standards set by AHPRA and the Pharmacy Board of Australia.
- **Privacy and regulatory compliance**
The pharmacy is subject to the Privacy Act 1988 (which includes the Notifiable Data Breaches scheme), the My Health Records Act 2012 and the Medicines and Poisons Act 2014. A breach from a pharmacy holding 10+ years of PII would trigger mandatory notification obligations the pharmacy is currently unprepared to meet.
- **Business continuity**
The pharmacy's revenue, regulatory standing and community reputation depends on uninterrupted business continuity. Any compromise to business continuity via a cyber attack would jeopardise operations and result in financial and reputational loss.

Limitations

Scope limitations

The maturity assessment only evaluated 20 of the subcategories defined in the NIST CSF 2.0. The subcategory selection was based on their relevance to a small-medium sized community pharmacy. The results therefore represented a scoped/targeted snapshot of cybersecurity maturity, rather than an exhaustive review.

Methodology limitations

The risk assessment uses a qualitative (likelihood and impact) method adapted from the NIST SP 800-30. Qualitative ratings are subjective and reflect the assessor's judgement based on available information and experience. A quantitative risk assessment method (e.g. FAIR Model) would produce a different output. This can be considered for individual high priority risks.

Fictional scenario

As stated in the title page, Cyber Pharmacy and any software mentioned are fictional. Where real entities and software are named (e.g. PBS, MHR, AIR, Microsoft), they are only referenced for operational realism. No real organisation, vendor, company or individual has been assessed.

Maturity Assessment

Framework

This assessment was conducted using the NIST Cybersecurity Framework (CSF) Version 2.0. The NIST CSF 2.0 organises cybersecurity outcomes across six Functions (Govern, Identify, Protect, Detect, Respond and Recover). Each Function has its own Subdivisions divided into Categories and Subcategories that describe specific cybersecurity outcomes. The NIST CSF 2.0 was chosen because it is widely recognised by Australian regulators and is directly mappable to Australian regulatory obligations such as the Essential Eight, Privacy Act 1988 and My Health Records 2012.

The risk assessment component was conducted and mapped against the NIST Special Publication (SP) 800-30 Revision 1. The NIST SP 800-30 provides a structured approach to identifying threat events, assessing likelihood and impact using qualitative scales (very low to very high). It determines the overall risk using a standardised risk matrix. The NIST SP 800-30 directly complements the NIST CSF 2.0 to produce a complete cybersecurity maturity assessment.

Together the NIST CSF 2.0 and the NIST SP 800-30 create a complete analytical chain by identifying the gaps, associating those gaps to risks and assessing the risk (by determining likelihood, impact and severity) to the organisation.

Scope

Twenty subcategories were selected across the six NIST CSF 2.0 Functions, based on their risk relevance to a small-medium sized community pharmacy handling sensitive PII. The selection criteria prioritised subcategories that addresses:

- The most likely threat scenarios for a small-medium sized community pharmacy
 - E.g. ransomware, phishing, insider misuse, credential compromise
- Australian regulatory obligations:
 - The Privacy Act 1988
 - NDB scheme
 - My Health Record Act 2012
 - Medicines and Poisons Act 2014

The twenty subcategories assessed are distributed as follows:

NIST CSF 2.0 Functions	Subcategory IDs	Count
Govern	GV.OC-01, GV.OC-02, GV.OC-03, GV.RM-01, GV.RM-02, GV.RR-02, GV.PO-02	7
Identify	ID.AM-01, ID.AM-02, ID.AM-03, ID.AM-04, ID.RA-04	5
Protect	PR.AA-01, PR.AA-05, PR.AT-01, PR.DS-11	4
Detect	DE.CM-01, DE.CM-02	2
Respond	RS.MA-01	1
Recover	RC.RP-03	1

Methodology

Information

The information used for this maturity assessment were obtained through stakeholder interviews. The interviewees include the owner, pharmacist manager, retail manager, intern pharmacist and dispensary assistants.

Maturity scoring

Each subcategory was scored against the NIST CSF 2.0 implementation tiers. The scores ranged from Tier 1 (partial) to Tier 4 (adaptive), as described in the table below.

Maturity scoring scale

Tier	Description
Tier 1 - Partial	Cybersecurity risk management is ad-hoc. Practices are reactive and not formalised. Little or no awareness of cybersecurity risk at the organisational level.
Tier 2 - Risk Informed	Risk management practices are approved by management and informed by organisational risk objectives. Practices may not be established as organisation-wide policy, but are understood and implemented in relevant areas.
Tier 3 - Repeatable	Risk management practices are formally approved and documented as policy. These policies are regularly updated and consistently applied across the organisation. Staff are trained and practices are regularly reviewed.
Tier 4 - Adaptive	The organisation adapts its cybersecurity practices based on lessons learned, predictive indicators and continuous improvement. Advanced capabilities include threat intelligence integration and automated response.

Gap analysis

For each subcategory, the gap between the current maturity score and a realistic target score was documented. This described what controls the pharmacy was missing (the gap) between the maturity score and the target score.

Business impact

Each gap resulted in a potential consequence for the business, which is the business impact. These consequences were described in this column.

Contextual Frameworks

Where relevant findings are contextualised against the following Australian regulatory frameworks and legislations:

- Privacy Act 1988
 - Notifiable Data Breaches scheme
- My Health Records Act 2012
- Medicines and Poisons Act 2014
- Pharmacy Board of Australia Code of Conduct and relevant professional standards
- ASD Essential Eight Frameworks

Findings

Detailed findings for each subcategory including; current state, maturity score, target state, gap analysis, business impact and recommendations, are presented in the cybersecurity maturity assessment register at Appendix A. The following section summarises key findings by Function.

Govern

Seven subcategories were assessed, and all seven are Tier 1.

The pharmacy has no cybersecurity strategy, no written policies, no risk register and no formally assigned cybersecurity responsibilities. Cybersecurity is not recognised in business planning and is absent from team discussions. The owner acts as the de facto decision maker for IT, but has no cybersecurity training. Legal obligations under the Privacy Act 1988, Medicines and Poisons Act 2014 and My Health Records Act 2012 are understood clinically, but are not understood in a cybersecurity context.

Identify

Five subcategories were assessed, and all five were Tier 1.

No hardware inventory, software inventory, network diagram or supplier registers exists. The pharmacy has networked devices ranging from dispensing computers, work stations, POS terminals and CCTV cameras. All the connected devices are on a single flat network without documentation of what connects to what. The supply chain with vendors (MSP and multiple SaaS platforms) have never been assessed for security risk. No documentation relating to cybersecurity has been documented between the pharmacy and the vendors. The owner occasionally uses their personal cloud storage account for work as well, which further expands

the pharmacy's data's attack surface. No cybersecurity risk assessment has been performed and no risk register exists. This is a significant risk because if threats like ransomware, phishing and MSP compromise materialise, these threats will not be identified or evaluated.

Protect

Four subcategories were assessed, and four were Tier 1

Identity and access management is the largest gap. The shared Email account without MFA is used by all staff members. Windows workstation auto log into shared local account. Some passwords are stored on sticky notes. There is no deprovisioning of former staff member's credentials. Staff members have not been taught about cybersecurity and there is no cybersecurity awareness training provided. Backups have not been verified, and backups rely entirely on implicit vendor trust.

Detect

Two subcategories were assessed, one was Tier 1 and one was Tier 2.

The pharmacy does not monitor the network or endpoint. There is no evidence of a SIEM, no managed EDR and no log monitoring. In a small-medium sized pharmacy, these controls are not typically expected, however the pharmacy should still take reasonable steps to detect cyber threats. Reasonable steps could include risk transference, for instance having an SLA with the MSP about cyber monitoring. Microsoft Defender runs in default configuration. Physical environment monitoring was scored as a Tier 2 because a monitored intruder alarm and IP CCTV cameras are operational. However, the IP CCTV cameras have default credentials, they sit on a flat unsegmented network, which represents an unmanaged risk in its own right.

Respond

One subcategory was assessed, and it was scored in Tier 1

The pharmacy has no incident response plan and no escalation paths in the event of a cyber attack. The MSP contract doesn't include anything about an incident response plan. The pharmacy doesn't have any cyber insurance. The pharmacy owner and other staff members are not familiar with the NDB reporting obligations or MHR Act breach notification requirements.

Recover

One subcategory was assessed, and it was scored in Tier 1

The pharmacy doesn't have a documented recovery procedure. The pharmacy implicitly relies on A-Dispense to restore clinical data, however this has never been verified or tested. The pharmacy has not requested for a vendor data restore attestation or evidence of a dataset restoration. In a ransomware scenario where the attacker has dwelt in the environment for an extended period of time, restoring unverified backups risks reintroducing malware or corrupted clinical data. This could create further NDB reportable events and clinical safety incidents.

Risk Assessment

Methodology

This risk assessment follows the approach described in the NIST SP 800-30 Rev 1. Risks were identified using the findings from the maturity assessment, which identified gaps across all six NIST CSF 2.0 Functions. For each risk identified; the threat event, the cause, the impact, the likelihood of that event occurring and the overall risk rating were documented.

The likelihood and impact were both scored qualitatively defined in the NIST SP 800-30 (very low, low, moderate, high or very high). The overall risk level was then determined by combining likelihood and impact using the NIST SP 800-30 risk matrix.

Qualitative likelihood and Impact scale

Level	Description for likelihood	Description for impact
Very high	Nearly certain to occur in 12 months	Multiple severe or catastrophic adverse event
High	Highly likely to occur in 12 months	Severe or catastrophic adverse event
Moderate	Reasonably likely to occur in 12 months	Serious adverse event
Low	Unlikely to occur in 12 months	Limited adverse event
Very low	Highly unlikely to occur in 12 months	Negligible adverse event

Risk Matrix

	Very low impact	Low impact	Moderate impact	High impact	Very high impact
Very high likelihood	 very low	 low	 moderate	 high	 very high
High likelihood	 very low	 low	 moderate	 high	 very high
Moderate likelihood	 very low	 low	 moderate	 moderate	 high
Low likelihood	 very low	 low	 low	 low	 moderate
Very low likelihood	 very low	 very low	 very low	 low	 low

Risk register

The following eight risks were identified and assessed. Risks are numbered R1 through to R8 for traceability and are ordered by overall risk level.

Risk ID	Risk	Cause	Impact	Likelihood	Risk Level
R1	Patient data breach via shared Email compromise	Single shared Email account without MFA and insecure password known to current and former staff	High: Exposure of patient PII including scanned prescriptions. Result in mandatory NDB notification.	Very high	High
R2	Ransomware attack on pharmacy network	No EDR, no monitoring, no tested backups, flat network, no phishing/cybersecurity employee training.	High: Operations halt, unknown restoration time, PII at risk of breach. Could result in financial and reputation damage.	High	High
R3	Regulatory non-compliance with NDB and MHR Act obligations	No familiarity with NDB 30 day window or MHR Act breach obligations, no response plan, no risk register, no escalation path.	High: Statutory timeframes are missed. OAIC enforcement action, civil penalties, AHPRA notifications, financial and reputational damage.	High	High
R4	Supply chain compromise via MSP.	MSP holds unattended remote desktop access to all workstations using shared desktop accounts. No security clause in contract regarding this.	High: Full environment compromise cascading to PII, employee financial details and MHR certificates. Pharmacy will be unaware until visible impact occurs.	Moderate	High
R5	Compromised embedded device as a network pivot.	CCTV on a flat network with default credentials, no firmware maintenance and accessible from other devices on the flat network.	High: CCTV footage lost, impacting S8 diversion/discrepancy investigations and theft response; breaching the Privacy Act and Medicines and Poisons Act. Further	Moderate	High

			compromise of the dispensing system, leading to PII breach.		
R6	Unauthorised My Health Record access or upload from compromised dispensing system sessions.	Compromised network via malware infection through falling for phishing attack or unpatched OS.	High: Unauthorised viewing of PII, incorrect uploads to MHR; all of which breaches the Privacy Act and triggers NDB 30 day window.	Moderate	High
R7	Unauthorised insider access to patient records.	No RBAC in A-Dispense, no user access control, no audit trail monitoring, no staff awareness of access boundaries. Accounts persist post staff resignation.	Moderate: Curiosity driven or malicious viewing of patient PII are unpredictable. Breach of patient confidentiality triggers Privacy Act and Pharmacy Board of Australia obligations. Responsibility and accountability falls on pharmacists and the owner.	Moderate	Moderate
R8	Operational disruption from dispensing system outage.	Sole reliance on A-Dispense without any confirmed backup SLA, no tested restoration, no defined RTO or RPO. Paper fallback only exercised for short outages.	Moderate: Inability to dispense, process PBS claims or accessing patient history of PII. Clinical risk to patients with urgent dispensing schedules, loss of revenue and reputation.	Moderate	Moderate

Mapping risks to NIST CSF 2.0 Controls

Each risk is mapped to the NIST CSF 2.0 subcategories. If these risks are implemented at the target maturity level, the risk would reduce. This mapping links the risk register directly to the maturity gaps identified in the assessment.

Risk ID	Risk	NIST CSF 2.0 subcategory
R1	Patient data breach via shared Email compromise	PR.AA-01, PR.AA-05
R2	Ransomware attack on pharmacy network	PR.AT-01, PR.DS-11, DE.CM-01, RS.MA-01, RC.RP-03
R3	Regulatory non-compliance with NDB and MHR Act obligations	GV.OC-01, GV.OC-03, GV.RR-02, RS.MA-01
R4	Supply chain compromise via MSP.	GV.OC-02, ID.AM-02, ID.AM-04
R5	Compromised embedded device as a network pivot.	ID.AM-01, ID.AM-03, DE.CM-01
R6	Unauthorised My Health Record access or upload.	GV.OC-03, PR.AA-01, PR.AA-05, PR.AT-01, RS.MA-01
R7	Unauthorised insider access to patient records.	PR.AA-05, DE.CM-01
R8	Operational disruption from dispensing system outage.	ID.AM-04, PR.DS-11, RS.MA-01, RC.RP-03

Recommendations and Roadmap

The following recommendations are prioritized based on:

- The risk assessment
- The maturity gaps
- Practical feasibility for a small-medium sized pharmacy without a dedicated IT team

The actions are grouped by priority (high priority and medium priority), then sequenced into a 12 month roadmap for the pharmacy.

Recommendations: High Priority (addressed within 6 months)

Priority ID	Recommendation	Description	Risk ID	NIST CSF 2.0
HP1	Develop privacy and security policy framework	Adopt a core set of policies for cybersecurity: • Data breach policy • Acceptable use policy • Data handling policy • Access control policy • Incident response policy Use healthcare-adapted templates rather than creating a policy from scratch. Owner to sign and staff to acknowledge at induction. To be reviewed annually.	R3	GV.OC-01, GV.OC-03, GV.RR-02, RS.MA-01
HP2	Define MSP responsibilities and contractual controls	Review the MSP contract to explicitly cover security monitoring scope, incident response support and breach notification timeline. Ensure SLA has been made with MSP for cybersecurity.	R4, R8	GV.OC-02, ID.AM-02, ID.AM-04, PR.DS-11, RS.MA-01, RC.RP-03
HP3	Implement basic cybersecurity monitoring	Engage the MSP to deploy managed EDR (e.g. SentinelOne) which will replace the basic Microsoft defender. Include alert triaging and escalation procedures.	R2, R5, R6, R7	DE.CM-01
HP4	Create incident response plan	Adopt an IR plan for: • Ransomware • Email compromise • Unauthorised PII record access Include in the IR plan: • NDB and MHR Act notification pathways Obtain cyber insurance with breach response panel access. Conduct a tabletop exercise within six months.	R1, R2, R3, R4	RS.MA-01
HP5	Eliminate shared credentials and enforce MFA, user activity log (each user should have	Migrate the shared Email to Microsoft 365 Business Standard with individual mailboxes and enforce MFA. Enable MFA on all accounts (where supported). Deploy a password manager for	R1, R3, R6	PR.AA-01, PR.AA-05

	their own accounts) and account re-authentication verification	employees.		
--	--	------------	--	--

Recommendations: Medium Priority (addressed within 12 months)

Priority ID	Recommendation	Description	Risk ID	NIST CSF 2.0
MP1	Asset inventory (hardware, software, suppliers)	Create a spreadsheet of all devices, software programs and service suppliers. Assign each item with a criticality rating. Review each quarterly.	R2, R4, R5, R8	ID.AM-01, ID.AM-02, ID.AM-03, ID.AM-04
MP2	Access control improvements	Implement RBAC throughout the pharmacy's employees. Define roles in A-Dispense and then assign the appropriate permissions based on the employees' role.	R1, R2, R6, R7	PR.AA-05
MP3	Back up verification	Obtain A-Dispense backup/recovery SLA in writing. Deploy a cloud storage backup for dispensing records, liaise with MSP. Ensure backup frequency, retention period, encryption, restoration testing and breach escalation responsibilities are outlined.	R2, R8	PR.DS-11, RC.RP-03
MP4	Employee cybersecurity training	Adopt an employee cybersecurity training platform e.g. KnowBe4. Make this mandatory at initiation and a refresher every year. Owner to review training results and provide further education where needed.	R1, R2, R7	PR.AT-01

Roadmap

Phase 1 (within the first 3 months)

- Focus:
 - Establish policies, accountability and vendor clarity
 - Establish the governance and contractual agreements between vendor
- Key actions:
 - Assign the owner as the cybersecurity lead for the pharmacy
 - Draft and sign:
 - Password policy
 - Data breach response
 - Acceptable use policy
 - Review and update MSP/A-Dispense contracts to include provisions for cybersecurity
 - Ensure cybersecurity insurance is obtained
 - Adopt an incident response plan
 - Develop a complete cybersecurity risk register aligned to NIST SP 800-30

Phase 2 (within the first 6 months)

- Focus:
 - Visibility and control around monitoring, access and asset management
- Key actions:
 - Deploy managed EDR via MSP
 - Build hardware, software and vendor inventories
 - Ensure sensitivity and criticality of the assets are assessed
 - Establish RBAC for all user accounts
 - Practice first tabletop exercise against the IR plan
 - Deploy cybersecurity awareness training program
 - Migrate Email to Microsoft 365 with MFA

Phase 3 (within the first 12 months)

- Focus:
 - Resilience, assurance and continuous improvement
 - Ensure current controls are working optimally
- Key actions:
 - Confirm A-Dispense backup SLA and verify restoration
 - Harden network
 - Implement network segmentation between master computer, workstations, embedded devices and non-work related devices
 - Maintain and update cybersecurity risk register quarterly, updating:
 - Likelihood
 - Impact
 - Risk rating
 - Treatment status
 - Accountable owners

Appendix

Appendix A - Cybersecurity Maturity Assessment Register

Governance								
Category	Subcategory ID	Description	Current state	Maturity Score	Target state	Gap	Business Impact	Recommendation
Organisational Context	GV.OC-01	The organisational mission is understood and informs cybersecurity risk management	No documented mission or purpose statement ties to cybersecurity. Cybersecurity doesn't appear to be part of business planning.	Tier 1 - Partial	Tier 2 - Risk Informed: the owner articulates, in writing, how cybersecurity supports the pharmacy's mission of safe dispensing and protection of patient health information. Reviewed annually.	Cybersecurity is not recognised as a business enabler. No link exists between the clinical and commercial mission and the protection of the systems that deliver it.	Without a mission-linked view of cybersecurity, security decisions are reactive and cost-driven rather than risk-informed.	Draft a one-page Cybersecurity Mission Statement signed by the owner that positions cybersecurity as an enabler of safe dispensing, Privacy Act compliance, and business continuity. Included in the staff handbook and review annually.
Organisational Context	GV.OC-02	Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered	Internal stakeholders (staff, owner) and external stakeholders (patients, MSP/A-Dispense, Services Australia, AHPRA) are known in a business sense, but their cybersecurity expectations have not been elicited or documented. Service agreements contain no data handling or security clauses.	Tier 1 - Partial	Tier 2 - Risk Informed: a documented stakeholder register identifying each stakeholder's cybersecurity-relevant expectations needs to be done and reviewed annually.	No documented understanding of what patients, regulators, or staff expect of the pharmacy's cybersecurity posture.	Unspecified expectations create contractual and reputational risk if a breach occurs involving PII. The pharmacy cannot demonstrate to patients or regulators that their privacy expectations are considered in decision-making.	Create a stakeholder register (owner, staff, patients, MSP, dispensing vendor, Services Australia, AHPRA, Pharmacy Guild). For each, document cyber-relevant expectations and obligations. Review if there is a change and every year.
Organisational Context	GV.OC-03	Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and	The Privacy Act 1988, My Health Records Act 2012, Healthcare Identifiers Act 2010, and Medicines and Poisons Act 2014 (WA) apply. Pharmacists understand patient confidentiality in a clinical	Tier 1 - Partial	Tier 2 - Risk Informed: a documented register of applicable cybersecurity-relevant laws, regulations, and contractual obligations, mapped to the control(s) that address each. Owner	No systematic awareness or tracking of cybersecurity-relevant legal obligations. The NDB 30-day assessment and notification window is not understood, and	If a breach occurred today, the pharmacy would almost certainly miss the NDB 30-day window and would be unaware of the tighter MHR Act obligations. This exposes the pharmacy to OAIC enforcement action, civil	Develop a compliance obligations register covering the Privacy Act, MHR Act. Owner to complete OAIC's free NDB guidance reading within 30 days. Map each obligation to the control that addresses it as controls are

		civil liberties obligations - are understood and managed	sense but the owner is not familiar with the NDB scheme or MHR Act breach notification obligations. No register of legal/regulatory cybersecurity obligations exists.		trained on NDB scheme. Reviewed annually and when regulations change.	MHR specific breach obligations (which can be triggered by any 'potential' compromise) are not operationalised.	penalties under the Privacy Act, and AHPRA notifications. This would result in financial and reputational loss.	built. Review with each update to legislation.
Risk Management	GV.RM-01	Risk management objectives are established and agreed to by organizational stakeholders	No cybersecurity risk management objectives have been established. No risk register exists. Cyber risk is not discussed at team meetings and is not considered in business decisions.	Tier 1 - Partial	Tier 2 - Risk Informed: documented cybersecurity risk management objectives aligned to the Cybersecurity Mission Statement, agreed by the owner, and communicated to staff.	No agreed objectives means no basis to measure progress, prioritise investment, or hold anyone accountable for security outcomes.	Without objectives, security activity is ad-hoc and reactive. Leaves the pharmacy more vulnerable to a cyber attack.	Document 3-5 cybersecurity risk management objectives (confidentiality of patient records, availability of dispensing, integrity of dispensed data, Privacy Act compliance, vendor oversight). Agree with the team and review annually.
Risk Management	GV.RM-02	Risk appetite and risk tolerance statements are established, communicated, and maintained	Risk appetite and tolerance are not defined in any form. The owner makes implicit risk decisions without articulating what level of risk is acceptable in a cybersecurity context. Example being a shared email account without MFA.	Tier 1 - Partial	Tier 2 - Risk Informed: a simple, plain-English risk appetite statement signed by the owner. For example: 'low tolerance for breaches of patient health information, moderate tolerance for short availability interruptions, zero tolerance for undetected S8 diversion or NDB reporting failures.'	No articulated risk appetite. Risk decisions are made implicitly, inconsistently, and usually in favour of convenience or cost.	Without a risk appetite statement, the owner cannot consistently decide which risks to accept, mitigate, or transfer. This leads to under-investment in high-impact controls (e.g. MFA) and over-acceptance of risks (e.g. shared Email with 16 users).	Draft a one-page risk appetite statement covering patient data confidentiality, dispensing availability, data integrity, regulatory compliance, and reputational harm. Owner to sign and review annually. Use it as the reference point for all treatment decisions in the risk register.
Roles, Responsibilities and Authorities	GV.RR-02	Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced	No role description at the pharmacy includes cybersecurity responsibilities. The Owner is the de facto decision-maker for all IT matters but has no formal cybersecurity training and no documented accountability. No staff member has a defined security role.	Tier 1 - Partial	Tier 2 - Risk Informed: the Owner is formally designated as the Information Security Officer (or equivalent) with cybersecurity responsibilities added to the position description. One employee pharmacist is nominated as deputy. Responsibilities communicated to all staff.	No formal cybersecurity accountability at any level. Default ownership sits with the owner informally but is not documented, delegated, or redundant.	The lack of cyber roles, responsibilities and accountability means security work is not done, not reviewed, and not reliably resumed if the owner is unavailable. During an incident, decision-making authority is unclear and may delay NDB assessment beyond the 30-day window.	Formally assign the Information Security Officer role to the Owner. Nominate the senior employee pharmacist as deputy. Ensure appropriate training is provided to ensure informed decision making in the context of cyber risks.

Policy	GV.PO-02	Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced	No written cybersecurity or information security policies exist. Absent policies include Information Security, Acceptable Use, Password, Access Control, Data Handling, Incident Response, Business Continuity, Third-Party, and Data Breach Response. QCPP SOPs cover clinical and quality domains only.	Tier 1 - Partial	Tier 3 - Repeatable: a core policy set appropriate for a 16-staff pharmacy - Information Security Policy, Acceptable Use, Access Control, Data Handling, Incident Response, and Data Breach Response. Reviewed annually and signed by the owner. Staff acknowledge on induction and annually thereafter.	Total absence of documented cybersecurity policy. Nothing is written down, so nothing is consistently enforced, reviewed, or auditable.	In the event of an incident or regulator inquiry, the pharmacy cannot demonstrate reasonable steps were taken to protect personal information (APP 11). This increases the likelihood of OAIC enforcement action and civil penalty exposure.	Adopt a core policy set over 6 months, starting with Data Breach Response (highest regulatory priority), then Acceptable Use and Password Policy (highest daily impact), then the remainder. Use healthcare-adapted templates rather than writing from scratch. Owner to sign and staff to acknowledge at induction and annually.
--------	----------	---	---	------------------	--	---	--	---

Identify								
Category	Subcategory ID	Description	Current state	Maturity Score	Target state	Gap	Business Impact	Recommendation
Asset Management	ID.AM-01	Inventories of hardware managed by the organization are maintained	No hardware inventory exists. The environment contains 3 dispensing workstations, 2 POS terminals, 1 office PC, the ISP modem/router, 4 IP CCTV cameras, and possible unmanaged staff personal phones connected to the WiFi. None is centrally recorded.	Tier 1 - Partial	Tier 2 - Risk Informed: a simple spreadsheet-based hardware inventory capturing device, location, owner, purpose, connectivity, and replacement date. To be reviewed yearly and updated when needed	No visibility over which devices exist, where they are, or what data they handle. Hardware devices that are not visible can increase the attack surface without anyone knowing.	The pharmacy cannot scope a breach, cannot reliably decommission devices, cannot verify patching coverage, and cannot answer basic questions in a regulator audit/investigation. All these "invisible" hardware devices could be a source of breaches which can result in financial and reputational loss.	Build a simple hardware inventory in a shared spreadsheet within 30 days. Include all workstations, POS terminals, network equipment, CCTV, and any device that connects to the network. MSP to assist with initial creation. To review quarterly.
Asset Management	ID.AM-02	Inventories of software, services, and systems managed by the organization are maintained	No software inventory exists. Business-critical software includes A-Dispense (cloud), Email (shared), Microsoft Defender, Windows 11, Remote Desktop (MSP agent), and browser-based access to /MHR/PBS/AIR. No register of vendors, purposes, data processed, or contract status.	Tier 1 - Partial	Tier 2 - Risk Informed: a software and services inventory listing each application, vendor, purpose, data categories, contract owner, and contract review date. To be reviewed annually.	No visibility of the SaaS footprint. Shadow IT (owner's personal cloud storage account storing some pharmacy records) is not recognised. Vendor onboarding and offboarding risks are not assessed.	The pharmacy cannot assess vendor risk, coordinate offboarding of a departed staff member across systems, or respond to a vendor breach notification with knowledge of what data was affected.	Build a software/services inventory alongside the hardware inventory. Include all SaaS and local applications, vendor, purpose, data processed, authentication, and MFA status. Flag the personal cloud storage account holding compounding records as shadow IT to be migrated or decommissioned within 90 days.
Asset Management	ID.AM-03	Representations of the organization's authorized network communication and internal and external network data flows are maintained	No documented network diagram or data flow mapping exists. The flat network means dispensing workstations, CCTV, POS and staff personal phones share one segment. Data flows to eRx, MHR, PBS and AIR are undocumented.	Tier 1 - Partial	Tier 2 - Risk Informed: a basic documented network diagram showing device inventory, network segments (even if minimal), data flow paths to eRx/MHR/PBS/AIR, and third-party access pathways (MSP Remote Desktop). Reviewed annually by the MSP.	No architectural basis for distinguishing authorised from unauthorised traffic. No understanding of where sensitive health information flows to and from. The MSP's Remote Desktop access pathway is not documented as a data-flow channel.	The pharmacy cannot scope an incident (and answer which systems were affected?), identify exposed systems in a breach, or complete a breach-impact assessment within the NDB 30-day window. It also cannot answer Privacy Act APP 1 transparency questions about data flows.	MSP to produce a simple network diagram within 60 days showing all devices, the single LAN segment, internet, and third-party data flows (A-Dispense, eRx, MHR, PBS, AIR, email). Review at each MSP contract renewal.

Asset Management	ID.AM-04	Inventories of services provided by suppliers are maintained	No supplier inventory exists. Known suppliers handling or accessing pharmacy data include: MSP, A-Dispense, ISP, eRx, Services Australia (PBS/Medicare/AIR) and MHR operator. No criticality rating, no contract register, no security assessment at onboarding.	Tier 1 - Partial	Tier 2 - Risk Informed: a supplier inventory capturing each third party, service provided, data involved, criticality (high/medium/low), contract expiry, and security posture indicator (e.g. hosting location, certifications claimed by vendor).	No systematic view of the supply chain. High-criticality suppliers (MSP with admin access, A-Dispense holding all patient records) are not distinguished from low-criticality ones, and no security-relevant contract terms have been confirmed.	A supplier compromise (MSP credential breach or A-Dispense breach) would catch the pharmacy unprepared. The pharmacy cannot verify whether vendors have notified it of incidents, and cannot meet its own NDB obligations for breaches at processors acting on its behalf. This would most likely result in fines and reputational loss.	Build a supplier inventory alongside hardware/software. Rate each by criticality. Prioritise reviewing the MSP contract and A-Dispense service agreement for security, backup SLA, and breach notification clauses within 90 days.
Risk Assessment	ID.RA-04	Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded	No cyber risk assessment has been performed. No risk register exists. Threats (ransomware, phishing, MSP compromise, insider misuse, device theft) and their potential impacts on the pharmacy have not been formally identified, assessed, or recorded.	Tier 1 - Partial	Tier 3 - Repeatable: a documented risk register identifying top 5-10 cyber risks with likelihood, impact, current controls, residual risk, and treatment decision. Reviewed every 6 months by the owner, or when material changes occur (new system, new staff, new regulation, incident).	No systematic understanding of threats, vulnerabilities, likelihoods, or impacts. The owner cannot prioritise investment because risk has never been quantified.	Without a risk register, treatment decisions are ad-hoc and the pharmacy cannot demonstrate risk-based decision-making to OAIC, an insurer, or a future purchaser.	Develop a risk register using NIST SP 800-30 as a method reference. Target 5-10 risks covering ransomware, phishing of shared email, MSP compromise, insider data misuse, device theft/loss, A-Dispense outage, unauthorised MHR access/upload, payment data compromise and regulatory non-compliance. Owner to review 6-monthly.

Protect								
Category	Subcategory ID	Description	Current state	Maturity Score	Target state	Gap	Business Impact	Recommendation
Identity Management, Authentication, Access Control	PR.AA-01	Identities and credentials for authorized users, services, and hardware are managed by the organization	A-Dispense accounts are individually named. However, shared Email is used by 16 current staff, Windows workstations use a shared local account per machine, MSP uses one shared technician account via Remote Desktop, no MFA is enabled anywhere and passwords are reused and written on sticky notes.	Tier 1 - Partial	Tier 3 - Repeatable: individual named accounts on all systems where technically feasible. MFA is enforced on all cloud services and remote access (e.g. each employee should have their own Windows login). Documented account deprovisioning procedure completed within 1 business day of staff departure. Annual user-access review.	Identity hygiene is the single largest gap in the current environment. Shared credentials (e.g. same Windows login and email access), no MFA, and sticky-note passwords collectively represent the most likely breach vector for the pharmacy.	The shared Email is a plausible initial access point for a full compromise: patient data exfiltration, supplier fraud (invoice redirection), and MHR credential phishing all flow from email compromise. A single successful phishing attempt likely triggers an NDB-reportable breach affecting confidential PII.	Priority actions within 90 days: migrate shared Email to Microsoft 365 Business Standard with per-user mailboxes and enforce MFA. (2) enable MFA on A-Dispense (if supported), and the MSP remote access. (3) adopt a password manager for staff and eliminate sticky notes
Identity Management, Authentication, Access Control	PR.AA-05	Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties	No documented access control policy. All A-Dispense users have broadly similar permissions irrespective of role. Local workstation admin rights are held by the shared local account and the MSP. No least-privilege model or separation of duties is applied. No periodic access review is performed and accounts persist for weeks to months after departure and later "re-named" when a new hire comes along.	Tier 1 - Partial	Tier 2 - Risk Informed: a documented Access Control Policy with role-based permissions (pharmacist, intern, dispensary assistant, retail, owner/admin). Standard users do not have local admin on workstations. Annual user-access review signed by the owner; can be done in parallel to QCPP review.	No least privilege. A dispensary assistant has the same visibility into patient records as a pharmacist. Former staff may retain access. Admin rights are excessive on every workstation.	Insider misuse (intentional or curiosity-driven access to patient records - e.g. a neighbour's prescription history) is undetectable and unpreventable. A compromised low-privilege account provides attacker access to the same data as a compromised pharmacist account.	Define 4-5 role profiles for A-Dispense and review with the vendor to align permissions. Remove local admin from standard workstation accounts (MSP to implement), and secure the admin account with MFA. Remove former staff accounts immediately. Schedule annual reviews thereafter.

Awareness and Training	PR.AT-01	Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind	No cybersecurity awareness training is delivered. Induction covers clinical, QCPP, privacy (clinical context), WHS, and customer service only. Phishing, passwords, mobile devices, data handling, and incident reporting are not covered. Staff knowledge derives from general media and informal comments.	Tier 1 - Partial	Tier 2 - Risk Informed: mandatory cybersecurity awareness training delivered at induction and annually thereafter. Content covers phishing recognition, password practices, data handling, device security, incident reporting, and NDB basics. Attendance recorded and should be made mandatory.	No structured awareness. Staff are the primary defence against phishing (the most likely breach vector) and have never been taught what to look for or how to report it.	The pharmacy carries all the exposure of a human-targeted environment without any of the controls. A single staff click on a credential phishing email likely triggers an NDB-reportable breach and prolonged response. Cyber insurance (when obtained) typically requires awareness training as a condition.	Adopt a low-cost healthcare-aware awareness platform (e.g. KnowBe4 or equivalent) with a 30-45 minute annual module and yearly phishing simulations. Mandatory at induction and annually. Owner to review simulation results yearly and address repeat clickers.
Data Security	PR.DS-11	Backups of data are created, protected, maintained, and tested	A-Dispense data is backed up by the vendor as part of the cloud service; pharmacy has no visibility of frequency, retention, or RTO. No pharmacy-side restore has ever been tested. No contractual SLA is confirmed. Back-office PC (compounding scans, script images) is not backed up at all. Email and CCTV have no backup.	Tier 1 - Partial	Tier 3 - Repeatable: documented backup arrangements for all critical data (dispensing, email, local files). Vendor backup SLAs confirmed in writing. Annual restore test for at least one data set, evidenced. Off-site and immutable copy for local files. CCTV retention policy documented.	Backup arrangements rest entirely on implicit vendor trust and informal local copies. No restore has ever been tested. Ransomware targeting the back-office PC would destroy clinical records not held elsewhere.	Ransomware or vendor outage would reveal the gap at the worst possible moment. If A-Dispense suffered a multi-day outage and backups were not restorable to the pharmacy's expected point, dispensing would halt for longer than the fallback paper process can realistically sustain. This would have huge financial and reputational damage, as the paper process is too inefficient and would not sustain long term.	Within 90 days: (1) obtain A-Dispense's backup/recovery SLA in writing from the vendor. (2) implement Microsoft 365 Backup or equivalent once email is migrated. (3) deploy a cloud backup solution for the office PC with versioning and 30-day retention. (4) conduct a documented test restore of the office PC within 6 months. (5) document CCTV retention.

Detect								
Category	Subcategory ID	Description	Current state	Maturity Score	Target state	Gap	Business Impact	Recommendation
Continuous Monitoring	DE.CM-01	Networks and network services are monitored to find potentially adverse events	No SIEM, no log aggregation, no network monitoring. Microsoft Defender writes locally and logs are not reviewed. Windows event logs retained at default and not reviewed. A-Dispense audit trail is not routinely reviewed. ISP modem produces no useful security logs.	Tier 1 - Partial	Tier 2 - Risk Informed: endpoint protection centralised via a managed EDR console (delivered by the MSP). Cloud service admin logs (when Email has migrated to Microsoft 365) reviewed monthly by the owner. A-Dispense audit trail sampled quarterly. Alerts on anomalies routed to the MSP for triage. An SLA should outline further details.	No detection capability. The pharmacy cannot answer the question 'has anything happened?' for any system.	Undetected compromise is the worst incident scenario because it fails the NDB 30-day clock by definition - the clock starts at 'awareness' but the pharmacy has no mechanism for awareness. The owner's own statement that deleted phishing emails 'may or may not' have been clicked on is an accurate description of present detection capability. Negligence should not be an excuse for non-compliance.	Engage MSP to deploy a managed EDR product (e.g. SentinelOne or Huntress) replacing default Defender. Monthly review for cloud admin logs, owned by the owner. Quarterly A-Dispense audit sampling. Full SIEM is not proportionate as this is a small-medium sized pharmacy, but a managed EDR is.
Continuous Monitoring	DE.CM-02	The physical environment is monitored to find potentially adverse events	Monitored intruder alarm is active after hours. IP CCTV cameras cover the retail floor, dispensary, DAA bench, rear entrance and S8 safe. Footage is stored 30 days on an on-premises in the back office. The CCTV is accessible from the network and has default or near-default credentials. S8 safe transactions logged via online DD registry, but access is not deliberately logged.	Tier 2 - Risk Informed	Tier 3 - Repeatable: CCTV retained 30 days (adequate), CCTV hardened with strong unique credentials, placed on a segmented VLAN, firmware maintained by MSP. Alarm tested periodically as per provider guidance.	Intruder and video monitoring exist, which is genuine capability. However, the CCTV itself is a poorly secured network connected device and the weakest link.	A compromised CCTV could be used as a pivot into the flat network. CCTV footage integrity (for supporting S8 or theft investigations) is not assured. This could be the backdoor for malicious cyber activities and ransomware.	Within 60 days: MSP to change CCTV credentials from default, update firmware, and place on a dedicated VLAN. Confirm the alarm provider's testing schedule.

Respond								
Category	Subcategory ID	Description	Current state	Maturity Score	Target state	Gap	Business Impact	Recommendation
Incident Management	RS.MA-01	The incident response plan is executed in coordination with relevant third parties once an incident is declared	No cyber incident response plan exists. No runbooks for ransomware, phishing compromise, lost device, or insider incident. Incident response roles and escalation paths are undefined. The owner is the default decision-maker by position, not by plan. The MSP contract does not include incident response service. No cyber insurance held. The owner and staff are not familiar with NDB or MHR Act notification obligations.	Tier 1 - Partial	Tier 3 - Repeatable: a documented Incident Response Plan with 3-4 scenario runbooks (e.g. ransomware, email compromise, lost/stolen device, suspected unauthorised access to patient records). Defined roles need to be established. Contact list including OAIC, MHR operator, insurer, MSP, legal. One tabletop exercise annually.	Complete absence of preparation for the events most likely to occur. No plan, no runbooks, no rehearsed coordination with the MSP, no insurer, no regulator contacts.	The NDB 30-day assessment window is effectively unusable without a response plan. In a real incident the owner would spend the first week orienting rather than assessing and notifying. The MHR Act's tighter obligations would almost certainly be missed. Legal, regulator, insurer, financial and reputational damage would be maximised.	Priority within 90 days: (1) adopt an Incident Response Plan template. (2) write 3 runbooks: ransomware, email compromise, unauthorised patient record access. (3) confirm MSP incident support terms in writing. (4) obtain cyber insurance including breach response. (5) conduct one tabletop exercise within 6 months, and then annually. Include NDB and MHR Act notification paths.

Recover								
Category	Subcategory ID	Description	Current state	Maturity Score	Target state	Gap	Business Impact	Recommendation
Incident Recovery Plan Execution	RC.RP-03	The integrity of backups and other restoration assets is verified before using them for restoration	No documented recovery procedure. Implicit reliance on the MSP/A-Dispense to restore dispensing data. No test restore has ever been performed by the pharmacy. No backup integrity verification is requested or reviewed.	Tier 1 - Partial	Tier 2 - Risk Informed: before any restoration, backup integrity is verified (vendor restore attestation for MSP/A-Dispense, test restore result for local files).	Backup integrity is assumed rather than verified. Compromised or corrupted backups could be restored into a clean environment and re-introduce malware or corrupted data.	A ransomware incident where the attacker has lurked in the environment for weeks would likely compromise the backups as well as the live system. Restoring without integrity verification either re-infects the environment or restores corrupted patient records - both of which create further NDB-reportable events and potential clinical safety incidents involving dispensing/clinical errors.	Add an integrity verification step to the Incident Response Plan. Before restore, require: (1) MSP/A-Dispense's written confirmation of the restore point. (2) local file restore to an isolated machine and review before reintroduction. (3) documented sign-off by the owner before production restore. Test annually as part of the tabletop exercise.